

TRANSITION-STATE
ZERO TRUST ADOPTION TOOLKIT
A Gap Analysis and Vendor-Neutral Operational Supplement
for NIST SP 1800-35

Prepared by Hassan Nawaz
Version 0.1 • Consolidated Community Review Draft • August 2026

This consolidated document combines a gap analysis with a practical toolkit. It is designed to complement NIST SP 1800-35 by explaining a narrow transition-state implementation need and then providing vendor-neutral worksheets, checklists, test records, assurance reviews, and pilot artifacts that organizations can use while legacy systems and newer zero trust controls coexist. It does not replace, modify, or claim endorsement by NIST, NCCoE, CISA, or any other government entity.

Primary reference: NIST SP 1800-35, Implementing a Zero Trust Architecture (Final, June 2025)

Cover Letter to the NCCoE Zero Trust Architecture Project Team

Dear NCCoE Zero Trust Architecture Project Team,

I am sharing this consolidated community-review draft as a practical supplement to NIST SP 1800-35, Implementing a Zero Trust Architecture. The guide provides substantial value through its nineteen example implementations, phased zero trust journey, standards mappings, and candid discussion of multi-vendor implementation and integration challenges.

The narrow problem addressed here is the transition state: the period in which legacy systems, temporary exceptions, hybrid dependencies, partial monitoring, and newer zero trust controls must coexist. The document first explains why this period deserves explicit operational governance, then provides working artifacts that make temporary conditions visible, owned, testable, and retireable.

The toolkit includes a transition-readiness scorecard, transition-state risk register, data sensitivity and migration sequencing worksheet, multi-vendor integration checklist, reusable validation test cases, handover checklist, 30/60/90-day assurance review, four-week pilot model, and feedback/versioning structure.

I would value technical feedback on whether the gap analysis is appropriately scoped and whether these artifacts complement SP 1800-35 in a useful, vendor-neutral way, particularly for organizations with limited modernization staff or uneven legacy documentation.

This draft makes no claim of NIST or NCCoE endorsement. It is offered for practitioner review, testing, and improvement.

Respectfully,

Hassan Nawaz

Cloud Infrastructure & Modernization Practitioner

1. Executive Summary

This consolidated edition combines the implementation rationale, scope boundaries, and reviewer-facing gap analysis with the full set of operational toolkit templates.

NIST SP 1800-35 explains that organizations should evolve existing environments toward Zero Trust incrementally and that there is no single implementation approach that fits all organizations. It also identifies recurring obstacles: limited resources for transition planning, training gaps, incomplete asset visibility, fragmented policy, and integration limitations across technologies.

This toolkit converts those recognized implementation challenges into working forms that a modernization team can use during planning, migration, validation, and handover. The central design principle is simple: temporary risk should be visible, owned, monitored, and retired rather than allowed to become a permanent operating condition.

Toolkit Components

1. Zero Trust Transition Readiness Scorecard
2. Transition-State Risk Register
3. Data Sensitivity & Migration Sequencing Worksheet
4. Multi-Vendor Integration Readiness Checklist
5. Zero Trust Transition Test Case Library
6. Handover & Operating Model Checklist
7. 30/60/90-Day Post-Migration Assurance Review
8. Four-Week Pilot Plan
9. Pilot Feedback Form
10. GitHub Publication Structure and Versioning Guidance

Use this document with the downloadable artifacts.

The Word edition is designed for review, workshops, and stakeholder discussion. The companion XLSX/CSV/Markdown artifacts are better suited to live assessments, data entry, version control, and GitHub distribution.

2. Why a Transition-State Supplement Is Needed

NIST SP 1800-35 already establishes the essential direction: zero trust is an incremental journey, not a single product deployment. It recommends discovery and inventory, mission-aligned access policy, assessment of existing security capabilities, risk-based gap closure, incremental implementation, verification, and continuous improvement.

The implementation gap addressed by this toolkit is narrower. During modernization, organizations may operate for months or years with legacy identity paths, hybrid dependencies, temporary firewall or access exceptions, incomplete telemetry, and mixed operating ownership. These conditions are not a separate target architecture; they are the temporary operating state that must be governed while the target architecture is being reached.

The purpose of the toolkit is to turn that middle state into explicit operational evidence: which dependency is blocking segmentation, which exception is temporary, who owns it, when it expires, which workload should migrate first, whether policy components can exchange the required signals, and whether the internal team can operate the environment after handover.

2.1 Proposed Supplement at a Glance

SP 1800-35 implementation theme	Operational need observed	Proposed companion artifact
Incremental evolution of existing environments	Temporary controls and dependencies can persist without explicit ownership	Transition-State Risk Register
Data classification is outside this project scope	Migration sequencing still depends on data sensitivity and business criticality	Data Sensitivity & Migration Sequencing Worksheet
Audience assumes existing cybersecurity capability	Smaller teams may need a structured baseline before technology selection	ZTA Transition Readiness Scorecard
Multi-vendor integration challenges are documented	Organizations need to test integration assumptions before procurement and deployment	Integration Readiness Checklist
Verification and periodic testing are recommended	Teams need reusable, evidence-oriented test cases	Transition Test Case Library
Training needs are identified; ZTA is ongoing	Operational ownership can degrade after project handover	Handover & Operating Model Checklist
Continuous improvement is required	Residual risks and expired exceptions need structured follow-up	30/60/90-Day Assurance Review

2.2 Design Boundary

This document uses the terms “aligned with,” “complements,” and “operationalizes.” It does not use “NIST-approved,” “NIST-certified,” or other wording that would imply endorsement. The toolkit also does not extend SP 1800-35 into OT/IoT or attempt to replace formal data-classification, privacy, legal, or enterprise risk-management processes.

3. Alignment with NIST SP 1800-35

SP 1800-35 Theme	Toolkit Response
Scope and audience	SP 1800-35 assumes an existing cybersecurity capability level and focuses on conventional enterprise IT. This toolkit adds lightweight worksheets intended to make the transition process easier to operationalize for teams that may have uneven documentation or limited staff.
Implementation challenges	Section 2.2 identifies resource constraints, training needs, incomplete asset inventory, limited communication-flow visibility, fragmented policy, and technology integration issues. The scorecard, risk register, and integration checklist directly operationalize those themes.

SP 1800-35 Theme	Toolkit Response
Integration findings	Sections 5.1-5.3 document out-of-the-box integration limitations, incomplete policy context, multiple policy decision points, and the value of SIEM/SOAR and data-security signals. The integration checklist turns those observations into pre-selection and validation questions.
Incremental implementation	Section 8 recommends discovery, policy formulation, use of existing capabilities, risk-based gap closure, incremental implementation, verification, and continuous improvement. The migration worksheet, test-case library, and 30/60/90-day review follow that sequence.

Important boundary.

SP 1800-35 explicitly places the risk and policy requirements of discovering and classifying data outside the project scope. The Data Sensitivity & Migration Sequencing Worksheet in this toolkit therefore does not attempt to replace formal data classification; it only helps teams connect approved sensitivity information to migration sequencing decisions.

4. Zero Trust Transition Readiness Scorecard

Use before major migration waves and repeat after material changes.

How this template complements SP 1800-35.

The scorecard provides a simple 0-5 maturity view across foundational capabilities that affect the safety of incremental Zero Trust adoption. Alignment: SP 1800-35 Sections 2.2 and 8.1-8.7.

Scoring Scale

Score	Meaning
0	Unknown or undocumented
1	Informal / ad hoc
2	Partially documented
3	Controlled but not repeatable
4	Repeatable and reviewed
5	Automated, monitored, and continuously improved

Blank Scorecard

Domain	Current	Target	Evidence Reviewed	Observed Gap	Owner
Asset inventory					
Identity readiness					
Privileged access governance					
Endpoint visibility					
Network segmentation readiness					
Logging and monitoring					
Data sensitivity awareness					
Backup & disaster recovery					
Application dependency visibility					
Documentation maturity					
Internal team readiness					
Exception governance					

Hypothetical Example

Domain	Current	Target	Observed Gap	Priority	Action
Asset inventory	2	4	Unmanaged branch devices not reconciled	High	Reconcile CMDB with discovery scan
Identity readiness	3	4	Legacy applications still use local accounts	High	Plan SSO/MFA transition
Segmentation readiness	1	3	Dependencies not fully mapped	Critical	Complete flow discovery before enforcement
Logging & monitoring	3	4	Cloud control-plane logs incomplete	High	Close telemetry gaps before cutover

Domain	Current	Target	Observed Gap	Priority	Action
Exception governance	1	4	Temporary rules lack expiry owners	Critical	Create exception register and retirement dates

5. Transition-State Risk Register

A governance record for temporary conditions created while legacy and Zero Trust controls coexist.

How this template complements SP 1800-35.

The register makes transition risks explicit by requiring ownership, compensating controls, monitoring, expiration dates, and measurable retirement conditions. Alignment: SP 1800-35 Sections 8.4-8.7.

Register Summary Template

Risk ID	System / Workload	Temporary Exception	Risk Rating	Status	Expiry	Primary Owner
---------	-------------------	---------------------	-------------	--------	--------	---------------

--	--	--	--	--	--	--

--	--	--	--	--	--	--

Risk Detail Sheet

Risk ID	[complete during assessment]
System / workload	[complete during assessment]
Business owner	[complete during assessment]
Technical owner	[complete during assessment]
Security owner	[complete during assessment]
Reason for exception	[complete during assessment]
Compensating control	[complete during assessment]
Monitoring method	[complete during assessment]
Expiration / review date	[complete during assessment]
Retirement condition	[complete during assessment]
Evidence link	[complete during assessment]
Review notes	[complete during assessment]

Hypothetical Example

Risk ID	System	Temporary Exception	Compensating Control	Expiry	Retirement Condition
TSR-001	Legacy HR portal	Local password authentication retained	MFA at VPN plus daily login review	2026-10-31	Retire local authentication after SSO upgrade
TSR-002	Payment reporting DB	Broad temporary subnet allow rule	Source-IP restriction plus database audit logging	2026-09-30	Replace broad rule after dependency discovery

Risk ID	System	Temporary Exception	Compensating Control	Expiry	Retirement Condition
TSR-003	Backup management	Privileged local service account	Credential vault and seven-day rotation	2026-11-15	Move service account into PAM-managed workflow

Operational rule.

A temporary exception without a named owner, monitoring method, and retirement condition should be treated as unmanaged transition risk.

6. Data Sensitivity & Migration Sequencing Worksheet

A lightweight decision aid that connects approved data sensitivity and operational readiness to migration-wave sequencing.

How this template complements SP 1800-35.

The worksheet deliberately does not classify data. It assumes the organization uses its existing approved classification and adds migration-oriented questions around ownership, identity, logging, backup/DR, dependencies, rollback, and retirement. Alignment: SP 1800-35 Section 1.2 (data-classification risk/policy requirements are out of scope) and Section 8.

Not a data-classification replacement.

Use enterprise-approved data classification, privacy, records-management, legal, and regulatory processes. This worksheet only helps decide how those inputs affect migration sequencing.

Practical Transition Questions

Area	Question	Why it matters	Evidence example
Data owner	Who can approve movement of this data/workload?	Prevents technical teams from making business-risk decisions alone.	Named owner / approval ticket
Sensitivity	What is the approved sensitivity level?	Affects sequencing, logging, encryption, and test evidence.	Classification label
Identity	Can the workload use enterprise identity/MFA now?	Legacy authentication may require a temporary exception.	SSO/MFA test
Logging	Will security-relevant activity remain visible after migration?	Reduces blind spots during hybrid operation.	SIEM source validation
Backup/DR	Can the workload be restored and can policy survive failover?	Recovery without security continuity is incomplete.	Restore/failover test
Dependencies	What upstream/downstream services must remain reachable?	Unknown dependencies can break segmentation or cutover.	Dependency map
Rollback	Can the team return safely to the prior state?	Supports controlled migration waves.	Approved rollback runbook
Retirement	What legacy path/control will be removed after success?	Prevents temporary risk becoming permanent.	Retirement ticket

Blank Migration Sequencing Worksheet

ID	Workload	Sensitivity	Mission Criticality	Identity	Logging	Backup/DR	Dependency Complexity	Proposed Wave
----	----------	-------------	---------------------	----------	---------	-----------	-----------------------	---------------

--	--	--	--	--	--	--	--	--

--	--	--	--	--	--	--	--	--

Hypothetical Example

Workload	Sensitivity	Criticality	Identity	Logging	DR	Dependencies	Wave	Rationale
Public website	Public	3	4	4	4	2	Wave 1	Low sensitivity and high technical readiness

Workload	Sensitivity	Criticality	Identity	Logging	DR	Dependencies	Wave	Rationale
HR portal	Restricted	4	2	3	4	3	Wave 3	Sensitive data plus legacy identity dependency
Financial reporting DB	Confidential	5	3	4	5	5	Wave 4	Mission-critical and high dependency complexity
Legacy API gateway	Internal	4	1	2	3	4	Hold	Unsupported client protocol and no rollback path

7. Multi-Vendor Integration Readiness Checklist

Use before procurement, pilot deployment, and major policy-enforcement changes.

How this template complements SP 1800-35.

The checklist converts documented integration findings into questions that can be validated before organizations depend on an end-to-end policy chain. Alignment: SP 1800-35 Sections 5.1-5.3 and 8.5.

ID	Readiness Question	Suggested Evidence	Status / Gap
INT-01	Can the policy decision function consume endpoint-compliance signals?	Integration configuration and test logs	
INT-02	Can endpoint-compliance information flow bidirectionally where required?	Connector/API test	
INT-03	Can SIEM/SOAR context influence access decisions in near real time?	SIEM/SOAR-to-PDP test	
INT-04	Can multiple PDPs share or reconcile risk context?	Architecture review and event correlation	
INT-05	Can non-compliant endpoints be blocked before or at access time?	Negative access test	
INT-06	Are protected resources themselves authenticated/health-checked where feasible?	Resource validation evidence	
INT-07	Is there a consolidated view of policies across enforcement points?	Policy inventory	
INT-08	Can data-security events inform access-policy decisions?	DLP/data-security integration test	
INT-09	Are discovery, SIEM, vulnerability scanning, and validation tools operational before rollout?	Tool coverage report	
INT-10	Can the organization rerun an access test suite after each migration wave?	Test evidence repository	

Hypothetical Review Snapshot

Control	Finding	Implication	Action
INT-02	One-way endpoint posture integration	One policy component can miss compliance changes detected elsewhere	Add reverse signal or compensating monitoring before rollout
INT-04	Two PDPs maintain separate risk views	Inconsistent access decisions possible	Define shared context source and policy reconciliation process
INT-09	Cloud audit logs incomplete	Migration wave would reduce observability	Close log-source gap before cutover

8. Zero Trust Transition Test Case Library

Reusable validation templates for incremental rollout and periodic assurance.

How this template complements SP 1800-35.

SP 1800-35 recommends repeatable testing across on-premises/cloud resources, managed/unmanaged endpoints, authorized/unauthorized subjects, and service-to-service requests. This library turns those scenarios into reusable test records. Alignment: SP 1800-35 Section 8.6.

Test Case Template

Test ID	[complete during validation]
Scenario	[complete during validation]
Preconditions	[complete during validation]
Action	[complete during validation]
Expected result	[complete during validation]
Actual result	[complete during validation]
Evidence collected	[complete during validation]
Owner	[complete during validation]
Frequency / trigger	[complete during validation]
Mapped transition risk	[complete during validation]
Pass / Fail	[complete during validation]
Remediation ticket	[complete during validation]

Starter Test Library

ID	Scenario	Expected Result	Trigger
ZT-T01	Authorized user + managed compliant endpoint	Access granted; session logged and reevaluated	After material policy change
ZT-T02	Authorized user + unmanaged endpoint to restricted cloud resource	Denied or restricted according to policy	Each migration wave
ZT-T03	Unauthorized user + managed endpoint	Access denied and evidence recorded	Quarterly
ZT-T04	Endpoint becomes non-compliant during active session	Session restricted/revoked according to policy	Quarterly
ZT-T05	Authorized service-to-service request	Approved service identity succeeds and is logged	Each release
ZT-T06	Unauthorized service-to-service request	Request denied and evidence captured	Each release
ZT-T07	Approved legacy identity exception	Access only through compensating control; exception linked	Monthly until retired
ZT-T08	Expired exception	Old path denied or change blocked; record closed	At expiry
ZT-T09	Segmentation with known dependency	Required flows continue; unapproved lateral paths blocked	Each segmentation wave
ZT-T10	DR failover with policy continuity	Identity, segmentation, logging, and access policy remain effective	At least annually

9. Handover & Operating Model Checklist

Use before implementation teams or vendors leave the engagement.

How this template complements SP 1800-35.

The checklist treats internal operating capability as part of security readiness rather than as end-of-project paperwork. Alignment: SP 1800-35 Section 2.2 (skills/training challenges) and Section 8.7 (continuous improvement).

Architecture & Configuration

- ☐ Current logical and physical architecture diagrams delivered.
- ☐ Trust boundaries and enforcement points documented.
- ☐ Identity, authentication, and authorization flows documented.
- ☐ Network segmentation and permitted dependencies documented.
- ☐ Infrastructure-as-code repository and deployment instructions handed over.
- ☐ Configuration baselines and approved deviations recorded.

Identity & Access

- ☐ Privileged roles reviewed and named owners assigned.
- ☐ Service accounts inventoried and ownership assigned.
- ☐ Legacy authentication exceptions listed with retirement dates.
- ☐ Break-glass / emergency access process tested.
- ☐ Recurring access review schedule established.

Monitoring & Security Operations

- ☐ Required log sources connected and validated.
- ☐ Alert ownership and escalation paths documented.
- ☐ Relevant SIEM/SOAR use cases validated.
- ☐ Vulnerability scanning coverage confirmed.
- ☐ Reusable security validation test suite stored in an accessible repository.

Backup, DR & Recovery

- ☐ Backup coverage confirmed for migrated workloads.
- ☐ Restore test completed.
- ☐ DR failover tested where applicable.
- ☐ Zero Trust policy continuity during DR validated.
- ☐ RPO/RTO assumptions confirmed with business owner.

Exceptions & Residual Risk

- ☐ Open transition exceptions reviewed.
- ☐ Every exception has an owner and review/expiry date.
- ☐ Compensating controls are documented.
- ☐ Retirement conditions are measurable.
- ☐ Residual risk has documented acceptance where required.

Operational Readiness

- ☐ Runbooks cover routine operations.
- ☐ Rollback procedures are current.
- ☐ Internal team completed training.
- ☐ Internal team performed at least one supervised operational task.
- ☐ Internal team can explain architecture and escalation paths without the implementer.
- ☐ 30/60/90-day assurance reviews are scheduled.

10. 30/60/90-Day Post-Migration Assurance Review

A lightweight mechanism to verify that transition controls remain effective after go-live and handover.

Review Point	Primary Questions	Evidence	Owner / Decision
Day 30	Are temporary exceptions still necessary? Are logs complete? Can operators follow runbooks?	Exception register, SIEM source status, operational tickets	
Day 60	Have dependency or access assumptions changed? Are recurring reviews occurring? Are unresolved gaps decreasing?	Access review, network-flow validation, risk register trend	
Day 90	Can remaining legacy paths be retired? Has the internal team operated independently? Are residual risks formally accepted or remediated?	Closure tickets, training/handover evidence, risk acceptance	

Assurance Review Record

Organization / scope

[complete during review]

Review date

[complete during review]

Review point (30 / 60 / 90)

[complete during review]

Open transition risks

[complete during review]

Exceptions closed since prior review

[complete during review]

New risks discovered

[complete during review]

Validation tests rerun

[complete during review]

Operational issues observed

[complete during review]

Actions agreed

[complete during review]

Next review date

[complete during review]

11. Four-Week Pilot Plan

A bounded way to test the toolkit with a local organization before wider dissemination.

Pilot boundary.

The pilot should not require production passwords, private keys, classified information, proprietary source code, unrestricted production access, or unnecessary sensitive data. System names and diagrams may be anonymized.

Week	Focus	Core Activities	Outputs
1	Discovery & Baseline	Confirm scope and owners; complete readiness scorecard; review asset, identity, network, logging, and DR evidence; identify legacy dependencies.	Scope statement; baseline score; evidence gaps; candidate workloads
2	Transition Risks & Integration	Create risk register; record temporary exceptions; complete integration checklist; identify policy/telemetry gaps.	Prioritized risks; integration actions; exception ownership matrix
3	Sequencing, Tests & Handover	Use migration worksheet; select 5-10 test cases; draft handover checklist; identify training needs.	Migration waves; test suite; handover gaps
4	Review & 90-Day Roadmap	Re-score priority domains; review residual risks; run authorized tests; gather feedback.	Pilot findings; 30/60/90 roadmap; feedback; proposed v0.2 changes

Minimum success criterion.

The pilot should identify at least one previously unmanaged transition risk, assign clear ownership, define an evidence-based retirement condition, and leave the organization with a repeatable operating artifact.

12. Pilot Feedback Form

Use feedback to improve v0.2 rather than treating the first version as finished.

Organization / team

Pilot dates

Reviewer role

1. Which toolkit artifact was most useful, and why?

2. Which artifact was least useful or duplicated an existing process?

3. Did the toolkit identify risks or dependencies that were not already visible?

4. Were any questions or scoring definitions difficult to interpret?

5. Did the readiness scorecard reflect the organization's actual maturity reasonably well?

6. Could the internal team use the artifacts without external consulting support?

7. Which fields or controls should be removed?

8. Which fields or controls are missing?

9. Would the organization use an updated version in another modernization effort?

10. May anonymized feedback be incorporated into future public versions?

Outcome Metrics

Transition risks identified

Risks assigned to a named owner

Risks with explicit retirement conditions

Reusable test cases created

Measurable operational improvement observed

13. Recommended Operating Sequence

1. Baseline the environment using the Readiness Scorecard.
2. Record temporary migration conditions in the Transition-State Risk Register.
3. Use approved data sensitivity plus operational readiness to sequence workloads.
4. Validate critical product and telemetry integrations before relying on end-to-end policy decisions.
5. Select reusable test cases for each migration/segmentation wave.
6. Complete handover before implementation-team dependency becomes permanent.
7. Review the environment at 30, 60, and 90 days and retire temporary exceptions as soon as evidence supports closure.
8. Capture pilot feedback, update the toolkit, and publish a versioned changelog.

Minimum Evidence Package for a Real Pilot

- Completed readiness scorecard with evidence references.
- Transition-state risk register with owners and retirement conditions.
- At least one migration sequencing decision tied to documented sensitivity/criticality and technical readiness.
- Completed integration-readiness checks for the pilot scope.
- Five or more repeatable validation test cases.
- Signed-off handover checklist or documented gaps.
- 30/60/90-day improvement roadmap.
- Independent participant feedback suitable for anonymized incorporation into v0.2.

14. GitHub Publication Structure

The repository should distribute the editable artifacts while this document serves as the consolidated human-readable edition.

```
transition-state-zero-trust-toolkit/
├── README.md
├── CHANGELOG.md
├── CONTRIBUTING.md
├── SECURITY.md
├── LICENSE
├── docs/
│   ├── Transition_State_Zero_Trust_Adoption_Toolkit_Consolidated_v0.1.docx
│   ├── nist_sp1800_35_alignment.md
│   └── reviewer_pitch.md
├── assessment-tool/
│   └── zero_trust_transition_readiness_scorecard.xlsx
├── templates/
│   ├── transition_state_risk_register.xlsx
│   ├── data_sensitivity_migration_sequencing.xlsx
│   ├── integration_readiness_checklist.csv
│   └── handover_operating_model_checklist.md
├── test-cases/
│   └── zero_trust_transition_test_cases.csv
├── pilot/
│   ├── 4_week_pilot_plan.md
│   └── pilot_feedback_form.md
```

Recommended Repository Description

Open, vendor-neutral operational templates for governing the transition state between legacy infrastructure and Zero Trust, aligned with NIST SP 1800-35.

Suggested Topics / Tags

zero-trust • nist • cybersecurity • cloud-migration • legacy-modernization • risk-governance • devsecops • infrastructure-as-code • public-sector

Versioning

- v0.1: community-review draft with hypothetical examples.
- v0.2: incorporate pilot feedback and clarify ambiguous fields.
- v0.3: add validated organization-specific case studies only with permission and anonymization.
- v1.0: stable public release after at least one independent pilot and documented review cycle.

15. Proposed Evaluation Criteria

Before a stable public release, the toolkit should be evaluated on whether it is usable without specialist interpretation, produces observable evidence rather than narrative opinion, exposes integration assumptions early, supports operational handover, and can be maintained as technologies and organizational requirements change.

Criterion	Question
Usability	Can a small IT/security team complete the artifact without consultant interpretation?
Clarity	Do users understand the difference between a temporary exception and an accepted long-term risk?
Evidence quality	Does each item point to observable evidence rather than narrative opinion?
Interoperability	Does the integration checklist expose signal and policy-flow assumptions before deployment?
Handover	Can internal staff perform core tasks after guided transfer?
Maintenance	Can the toolkit be updated as technologies, threats, and organizational requirements change?

16. Limitations and Non-Claims

- This toolkit is not a cybersecurity certification or compliance determination.
- It does not replace NIST SP 1800-35, NIST SP 800-207, formal data-classification guidance, enterprise risk-management processes, privacy review, or legal review.
- It does not constitute a FedRAMP authorization package, audit opinion, or guarantee of breach prevention.
- It does not claim endorsement, approval, certification, or validation by NIST, NCCoE, CISA, or any other government entity.
- Hypothetical examples are illustrative only and should not be presented as results from a real organization.
- Organizations should adapt the templates to their own mission, risk tolerance, architecture, regulatory obligations, and operating model.

The immediate request is narrow: feedback on whether the gap analysis and artifacts address a useful implementation need complementary to SP 1800-35. If the concept is useful, the proposed next step is to publish the v0.1 repository, run one or two non-sensitive pilots, capture implementation feedback, and revise the toolkit transparently.

Requested Feedback / Proposed Next Step

1. Do these artifacts complement the implementation focus of SP 1800-35 without duplicating existing NIST/NCCoE material?
2. Are the transition-risk ownership and retirement fields sufficient for practical use?
3. Does the migration sequencing worksheet stay appropriately outside formal data classification while still adding operational value?
4. Are the integration-readiness questions sufficiently vendor-neutral?
5. Does the test-case library capture the right minimum validation scenarios for incremental rollout?
6. What should be removed, added, or simplified before a v1.0 public release?

17. References

1. NIST Special Publication 1800-35, Implementing a Zero Trust Architecture, Final, June 2025. DOI: 10.6028/NIST.SP.1800-35.
2. NIST Special Publication 800-207, Zero Trust Architecture, August 2020.
3. NIST Cybersecurity Framework (CSF) 2.0, February 2024.
4. NIST Special Publication 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations.

Feedback channel in SP 1800-35.

The final SP 1800-35 document states that comments on the publication may be submitted to the NCCoE Zero Trust Architecture project email identified in the publication. Any outreach should be framed as a request for technical feedback, not as a request for endorsement.

Appendix A. Companion Editable Artifacts

Artifact	Format	Primary Use
Zero Trust Transition Readiness Scorecard	XLSX	Scoring, evidence capture, target maturity
Transition-State Risk Register	XLSX	Exception ownership, monitoring, expiry, retirement
Data Sensitivity & Migration Sequencing	XLSX	Workload sequencing using approved sensitivity and readiness
Integration Readiness Checklist	CSV	Multi-vendor integration validation
Zero Trust Transition Test Cases	CSV	Repeatable verification library
Handover & Operating Model Checklist	Markdown	Operational handover and independence
Four-Week Pilot Plan	Markdown	Pilot execution
Pilot Feedback Form	Markdown	Independent feedback and iteration
NIST SP 1800-35 Alignment Notes	Markdown	Traceability and scope boundaries
Consolidated Toolkit	DOCX	Human-readable publication / review edition